

SOM CHANDRA

somchandra.infosec@gmail.com • [9507988170](tel:9507988170) • [somchandra17](https://github.com/somchandra17) • [somchandra17](https://www.linkedin.com/in/somchandra17) • [TryHackMe](https://tryhackme.com/members/somchandra17) • somm.tf

Summary

- Application Security / Cyber Security Engineer focused on web, API, Android, and iOS VAPT, with hands-on experience in gray-box testing, mobile runtime analysis, AppSec automation, vulnerability validation, and developer-facing remediation.
- Own end-to-end internal VAPT and AuthenticOne external coordination; ship tooling for revalidation, vendor/internal report-to-Jira filing, and weekly Nessus Advanced scanning.
- Security+ and eWPTXv2 certified; Top 1% on TryHackMe with Hall of Fame and 20+ NCIIPC India responsible-disclosure acknowledgments.

Technical Skills

- **Application Security:** Web/API/Mobile VAPT, OWASP Top 10, OWASP MASVS, gray-box testing, manual exploitation, vulnerability triage, false-positive validation, secure remediation review
- **Mobile Security:** Android/iOS testing, root/jailbreak detection, SSL pinning validation and bypass testing, Frida runtime analysis, WebView security, Google Play Integrity, anti-tampering
- **Security Tools:** Burp Suite, OWASP ZAP, Nessus, Nmap, nuclei, Frida, MobSF, JADX, apktool, drozer, ADB, Postman, Wireshark, Ghidra, testssl
- **Automation & Development:** Python, Bash, Kotlin, Java, JavaScript, Node.js, REST, GraphQL, Docker, Git, Linux, FastAPI
- **Infrastructure & Workflow:** AWS EC2/AMI, Kubernetes, Jenkins, Azure, Jira, Confluence, security reporting, vendor VAPT coordination

Experience

MoveInSync

Cyber Security Engineer

Jun, 2025 – Present

Bengaluru, Karnataka, India

- Conduct gray-box VAPT across web, API, and mobile product surfaces (ETS, WIS, Driver, Guard, and related apps); coordinate AuthenticOne external intake, triage, and fix validation.
- Validate and revalidate Android controls against rooted-device and Frida runtime attacks, including Play Integrity and root-detection disposition with engineering remediation follow-up; built a Driver App Byte Decoder Burp extension for driver-app traffic analysis.
- Triage UST SecurityScorecard findings against production (Feb 2026 Detailed Report mostly false positives; Jun 2026 prod header/TLS checks clean); file rescan evidence and Jira follow-up.
- Author the Jenkins CI/CD secret-exposure RCA and drive post-incident credential inventory and rotation verification, with leadership status updates through remediation tracking.
- Convert vendor and internal VAPT PDF/HTML into developer-ready Jira Stories and Bugs via **ExternalVAPT2JIRA** (dry-run until approve), including AuthenticOne report disposition.
- Build and ship **vapt-revalidator**: FastAPI console and worker driving IDOR/BAC retests through Burp and browser tooling into human-approved Jira comments and QA transitions.
- Migrate **Nessus** from Azure Windows to hardened AWS Linux, then automate weekly Advanced scans through Stage 1 to Stage 2 (Sunday IST); publish reports to Google Drive and Slack.

MoveInSync

Application Security Intern

Jan, 2025 – May, 2025

Bengaluru, Karnataka, India

- Supported API, web, and mobile security testing through endpoint enumeration, manual vulnerability validation, evidence capture, and reproducible ticket creation.
- Performed pre-assessment sanity testing for Android/iOS builds to identify blocking issues before external VAPT engagements.
- Prototyped API discovery and external exposure checks that later informed reusable internal security automation.
- Assisted with Nessus scan review, triage, reporting, documentation, and developer follow-up through remediation closure.

Securaeon Initiative

Cyber Security R&D Intern

Feb, 2022 – Jul, 2022

Remote/Kolkata, West Bengal

- Created security walkthroughs, proof-of-concept material, and practical lab content for upcoming cybersecurity products and courses.

Bugcrowd

Security Researcher

Oct, 2021 – Dec, 2021

Freelance

- Reported web security vulnerabilities through open bug bounty programs, including findings later recognized in Hall of Fame listings and responsible-disclosure acknowledgments.
- Communicated impact, proof of concept, and remediation context to program security teams to support timely validation and closure.

Projects

Burp AI Agent - Upstream Open-Source Contribution

Apr, 2026

[six2dez/burp-ai-agent](https://github.com/six2dez/burp-ai-agent)

- Contributed to an upstream Burp Suite extension for AI-assisted analysis and testing workflows.
- Merged NVIDIA NIM backend support and OpenAI-compatible hooks in Kotlin, plus HTTP 429 chat handling so AI-assisted Burp sessions stay reliable (PR 44).

TrashDroid

Apr, 2026

[Somchandra17/TrashDroid](https://github.com/Somchandra17/TrashDroid)

- Built a terminal Android DAST framework in Python that orchestrates adb, drozer, apktool, and related tooling across nine assessment phases.

- Produced AI-ready Markdown reports covering exported components, storage, logcat, memory, backup, manifest, post-logout behavior, and PII detection.

TrashiOS

Jun, 2026

 [Somchandra17/TrashiOS](#)

- Built an iOS SAST/DAST counterpart pairing libimobiledevice with Frida/objection for static and dynamic assessment on a jailbroken USB device.
- Ran a thirteen-phase flow with AI-ready reporting grounded in OWASP MASTG/MASVS; used a scrubbed office copy (iOSAutoAudit) to triage findings on ETS UAT iOS.

TrashRecon

Mar, 2026

 [Somchandra17/TrashRecon](#)

- Dockerized a reconnaissance framework chaining 17 tools across ten phases from subdomain enumeration through optional nuclei.
- Supported resume and structured JSON outputs for external attack-surface mapping.

TrashFrame

Jun, 2026

 [Somchandra17/TrashFrame](#)

[frames.somm.tf](#)

- Built a Next.js app that turns Spotify album/track links into printable multi-theme posters with DPI export ([frames.somm.tf](#)).

w-bonkers

Jul, 2026

 [Somchandra17/w-bonkers](#)

- Built a Python NSE portfolio autopilot for Claude Code/Codex with a deterministic state.json engine and Todoist order loop (local archives; no auto-trading).

Certifications

CompTIA Security+ (SY0-701)

Dec, 2024

by CompTIA

eWPTXv2 - eLearnSecurity Web Application Penetration Tester eXtreme

Jan, 2023

by eLearnSecurity

Achievements

Top 1% on TryHackMe

Security Recognition

- **Mastercard Inc.:** SSTI escalated to LFI (P1)
- **Rakuten:** Session Fixation (P2)
- **Chaturbate Inc.:** Stored XSS (P2)

20+ NCIIPC India Acknowledgments

- Reported client-side authentication bypass, missing rate limits, XSS, SQL injection, and account takeover vulnerabilities through responsible disclosure.

CTFs

- 5th Place, OWASPLPU CTF 2022
- 9th Place, WTFCTF 2022
- 34th Place, RuCTF 2022

Education

B.Tech in Computer Science and Engineering (Hons.)

Jun, 2021 – May, 2025

Lovely Professional University, Jalandhar, Punjab

- Specialization: Cybersecurity and Blockchain
- CGPA: 7.73